



System Security & Compliance

Week 4 • Day 2 • Technical Architecture & Constraints

TPM Academy



Day 2 Objectives

- Apply the **STRIDE threat-model** to a feature's data flow
- Walk a **data-flow diagram**: arrows (in motion) + boxes (at rest)
- Recognize the **three compliance frames**: SOC 2, privacy, industry-specific
- **Rewrite** the Week-3 first-draft security NFRs at architecture level
- Produce a **security brief** ready for a security-team conversation



Today's Shape

Clock	Block	Outcome
09:00 – 09:15	Opening	Recap §§1–2; print STRIDE card
09:15 – 10:30	Block 1 + Activity 1	STRIDE calibration on a public example
10:45 – 12:00	Block 2 + Activity 2	STRIDE pass on your PRD feature
13:00 – 14:15	Block 3 + Activity 3	Compliance frame + updated NFRs
14:30 – 16:00	Block 4 + Activity 4 + Wrap	Security brief + AI cross-check

Block 1 — STRIDE

Six letters, six categories of threat



The Six Letters

Letter	Threat	Plain language
S	Spoofing	Pretending to be someone you aren't
T	Tampering	Changing data without authorization
R	Repudiation	Denying you did something you did
I	Information disclosure	Exposing data to wrong party
D	Denial of service	Blocking legitimate use
E	Elevation of privilege	Doing more than your role allows

Most-missed letter: Repudiation. The least intuitive. Teams that build features without audit trails routinely miss it.

The Data-Flow Lens

A threat model is a walk along the data flow. Where does data come from, where does it move to, where does it stop, who can read or change it at each step?

```
[User] →(auth)→ [Frontend] →(API)→ [Backend service]
↓
[Datastore]
↓
[Audit / events]
↓
[Downstream consumer]
```

- Threats live at **arrows** (data in motion)
- Threats live at **boxes** (data at rest)
- Each STRIDE letter applies to one or more

Activity 1 — STRIDE on Password Reset

Triads • 35 minutes

Walk a password-reset flow. Apply STRIDE per step. Cull to top 5 threats.

- 5 min: sketch the flow
- 20 min: STRIDE walk (6 letters per step)
- 10 min: cull to top 5



5 + 20 + 10

Block 2 — STRIDE Your Feature

Apply the calibrated walk to your PRD



Threat Template

```
### Threat – <short name="">
**STRIDE letter:** S / T / R / I / D / E
**Where:** [box or arrow in your data flow]
**Scenario:** [one sentence]
**Likelihood:** L / M / H
**Impact:** L / M / H
**Mitigation:** [specific control; "TLS" is not a complete answer]
**Owner:** [security team, you, the architect]</short>
```

"Use security best practices" is not a mitigation. **"Validate JWT signature against IdP-published key, with 5-minute clock skew"** is.



Worked Threat (FieldPulse reconcile)

```
### Threat – Repudiation of reconcile submission
**STRIDE letter:** R
**Where:** [Mobile app] →(submit)→ [Reconcile API]
**Scenario:** A dispatcher denies submitting a reconcile that
triggered an incorrect timecard charge.
**Likelihood:** L
**Impact:** H (wage-and-hour audit exposure)
**Mitigation:** Server-side audit event with: dispatcher_id, ticket_ids,
timestamp, signed JWT used, user-agent. 24-month retention.
Tied to NFR-Audit-Trail.
**Owner:** Security architect (validates retention; we own implementation).
```

Activity 2 — STRIDE Your PRD

Triads • 40 minutes

Re-draw the data flow from yesterday's integration table + PRD §5. Run the STRIDE walk. Document top 5 threats.

- 10 min: re-draw data flow
- 20 min: STRIDE walk
- 10 min: top 5 threats with template



10 + 20 + 10

Block 3 — Compliance + NFR Rewrite

Three frames; rewrite the first-draft NFRs



Three Compliance Frames

SOC 2 Type II

Operational controls (security, availability, confidentiality, processing integrity, privacy). Most B2B SaaS sales requirement.

Privacy regimes

GDPR, CCPA, US state privacy laws. Personal data handling, consent, deletion.

Industry-specific

HIPAA, PCI-DSS, FERPA, SOX, etc. Pulled in by data type or customer industry.

The TPM job: not to write the compliance program. Flag which frame applies; drive the conversation with the responsible team.



The NFR Rewrite

Week 3 NFR (first draft)	Week 4 update	Why
"AuthN: SSO required"	SAML 2.0 + scope `reconcile.write`	Threat model surfaced privilege scope
"Audit logging"	Specific event list (S/T/R coverage)	SOC 2 + Repudiation threats
"Encryption"	TLS 1.2+ + at-rest managed keys + log redaction	Information Disclosure threats
(none)	Data residency: same region as Tickets	Latency + privacy regime

The TCD §3 doesn't replace PRD §7. It deepens it. Both ship.

Activity 3 — Compliance + NFR Rewrite

Triads • 40 minutes

Identify which frames apply; list the specific controls each requires. Rewrite the security & compliance NFRs.

- 10 min: compliance frame check (SOC 2 / privacy / industry)
- 15 min: list specific controls per frame
- 15 min: rewrite the NFRs (req / defense / verification)



10 + 15 + 15

Block 4 — The Security Brief

The document you'd hand to security before the meeting



Security Brief Structure

```
# Security brief – <feature>
```

```
<h2 id="summary-3-bullets">Summary (3 bullets)</h2>
```

```
<h2 id="data-flow">Data flow</h2>
```

```
<p>(link to TCD §2)</p>
```

```
<h2 id="top-5-threats-from-stride-pass">Top 5 threats (from STRIDE pass)</h2>
```

```
<h2 id="open-questions-for-security-team">Open questions for security team</h2>
```

```
</feature>
```

Decisions we've already made (and their justification)

- **Short:** security partner reads in 5 min
- **Specific:** "open questions" are concrete asks
- **Confident:** "decisions made" shows you didn't outsource thinking



AI Cross-Check

```
Role: Senior security architect.  
Context: <paste the="" security="" brief="">  
Task: What's the strongest objection a senior security architect  
would raise after reading this brief?  
Constraints:  
- Be specific to the data and integrations described  
- Do not suggest generic best practices  
- Flag any place rationale relies on un-stated assumptions  
Format: Top 3 objections, each with a scenario.</paste>
```

Cross-validation rule: AI surfaces possibilities; you decide what's real.
Treat output as a list of leads to investigate, not findings to adopt.

Activity 4 — Security Brief

Triads • 45 minutes • Wrap

5 questions for security; 3 likely pushbacks; draft the 1-page brief; AI cross-check.

- 15 min: 5 questions for security
- 10 min: 3 predicted pushbacks + responses
- 15 min: draft the brief
- 5 min: AI cross-check + provenance note



15 + 10 + 15 + 5 = 45-min wrap



Day 2 Wrap

What we built

- STRIDE walk through your feature's data flow
- Top-5 threats with mitigations + owners
- Updated security & compliance NFRs
- 1-page security brief
- TCD §3 drafted

What opens tomorrow

- **Mapping high-level system components**
- C4 model (Context + Container)
- Convert your integration table into a diagram

Bring to Day 3: Your TCD §§1–3 + the integration table from Day 1. Tomorrow we draw.

Questions & Reflection

What's the threat you found that wouldn't have shown up without STRIDE?